Host & Network Penetration Testing

System / Host-Based Attacks — CTF 1

Professional eJPT Lab Write-Up

LAB PLATFORM	INE / eJPT Training Lab
TARGETS	target1.ine.local	target2.ine.local
PRIMARY TECHNIQUES	HTTP Basic Authentication • WebDAV • ASP Web Shell • SMB
TOOLS	Nmap • Metasploit • Hydra • Cadaver • smbclient
OBJECTIVE	Capture four flags across two intentionally vulnerable Windows hosts

Scope & Ethics. All testing documented here was performed against the deliberately vulnerable INE lab environment. The commands and techniques are intended for authorized security testing, certification preparation, and isolated practice only.

Reference methodology adapted from the linked InfoSec Write-ups walkthrough and cross-checked against publicly available versions of the same INE lab walkthrough. The wording and presentation here are original.

1. Executive Summary

This assessment demonstrates a complete, tool-assisted attack chain against two Windows training targets. The first host exposes an IIS service protected by weak HTTP credentials and a writable WebDAV directory. After recovering the bob password, authenticated WebDAV access allows an ASP web shell to be uploaded and used to inspect the C: drive. The second host exposes SMB; credential guessing identifies a privileged administrator account, which is then used to enumerate administrative shares and retrieve files.

The lab is valuable because it shows how individually simple weaknesses can be chained: weak authentication → authenticated access → unsafe file upload → command execution, and weak SMB credentials → administrative share access → sensitive file retrieval.

Attack Path

```
TARGET 1
Nmap → HTTP Basic Auth → Hydra → bob:password_123321
↓
Authenticated WebDAV → upload webshell.asp
↓
ASP command execution → C:\flag2.txt

TARGET 2
SMB enumeration → Metasploit smb_login → administrator:pineapple
↓
smbclient → C$ administrative share → flag3.txt
↓
Users\Administrator\Desktop → flag4.txt
```

Key findings

• Weak HTTP credentials: the supplied username bob was protected by a dictionary-guessable password.

• Writable WebDAV: authenticated users could upload server-side ASP content, creating a path to command execution.

• Weak SMB credentials: the privileged administrator account accepted a weak password.

• Excessive administrative access: the recovered account could access the C$ administrative share and the Administrator profile.

2. Lab Scope, Objectives & Methodology

The INE exercise provides two Windows targets. The lab objective is to identify the relevant services, exploit the weaknesses indicated by the task hints, and recover four hidden flags. The recommended files include a common username list, a Unix password list, and an ASP web shell.

Methodology

```
1. Reconnaissance
2. Service identification
3. Authentication testing
4. Credential discovery
5. Authenticated enumeration
6. Controlled exploitation
7. Evidence collection
8. Security impact and remediation analysis
```

The workflow intentionally separates discovery from exploitation. This makes the reasoning reproducible and mirrors a professional penetration-testing engagement: establish what is exposed first, then select the least complex attack path supported by the evidence.

Tools & Purpose

Tool	Purpose
Nmap	Port, service and protocol identification
Metasploit Framework	SMB auxiliary enumeration and credential testing
Hydra	HTTP Basic Authentication password guessing
Cadaver	Authenticated WebDAV interaction and file upload
smbclient	Authenticated SMB share enumeration and file retrieval

3. Target 1 — WebDAV Attack Chain

Target: target1.ine.local

The first target is an IIS web server. The supplied evidence shows SMB and HTTP-related enumeration in Metasploit, followed by a focused attack on the HTTP/WebDAV surface. The most important clue is that WebDAV is protected by authentication but permits authenticated file operations.

3.1 SMB Module Discovery and Service Fingerprinting

Metasploit was first used to identify available SMB auxiliary modules and fingerprint the target. The successful SMB version check reported SMB versions 2 and 3, with SMB 3.1.1 preferred.

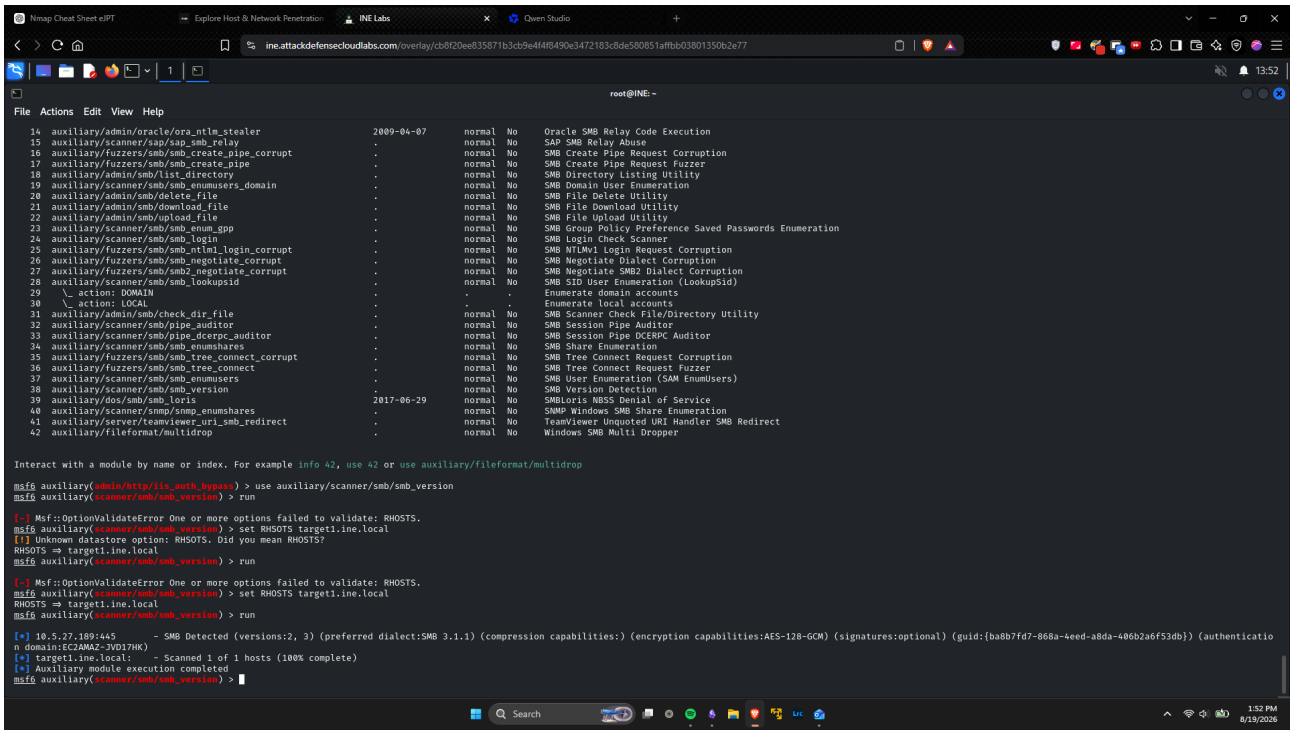


Figure 1. Metasploit SMB auxiliary module discovery and SMB version detection against target1.

The initial run also illustrates a common operational issue: Metasploit requires the target to be supplied through the module's RHOSTS option. Correcting the option allowed the module to complete successfully.

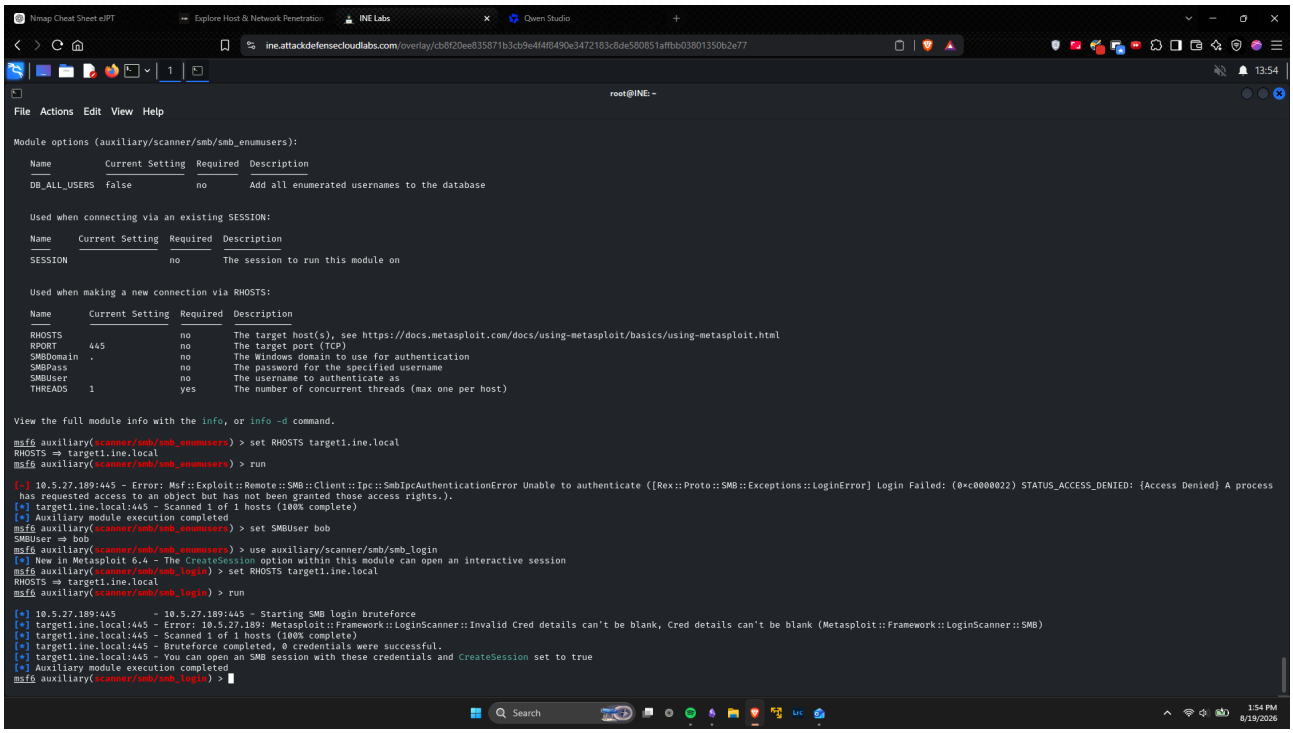


Figure 2. SMB user-enumeration attempt followed by an unsuccessful SMB login attempt; the output demonstrates why valid credentials are required for authenticated enumeration.

3.2 Recovering the Web Credential

The HTTP service on target1 requested authentication. Because the lab explicitly identified bob as a potentially weak account, a targeted password dictionary attack was performed against HTTP Basic Authentication.

```
hydra -l bob -P /usr/share/metasploit-framework/data/wordlists/unix_passwords.txt target1.ine.local
http-get /
```

Hydra identified a valid credential pair:

Username: bob
Password: password_123321

This is a classic example of authentication weakness rather than a software exploit. The service itself was functioning as designed; the security failure was the acceptance of a weak, guessable password.

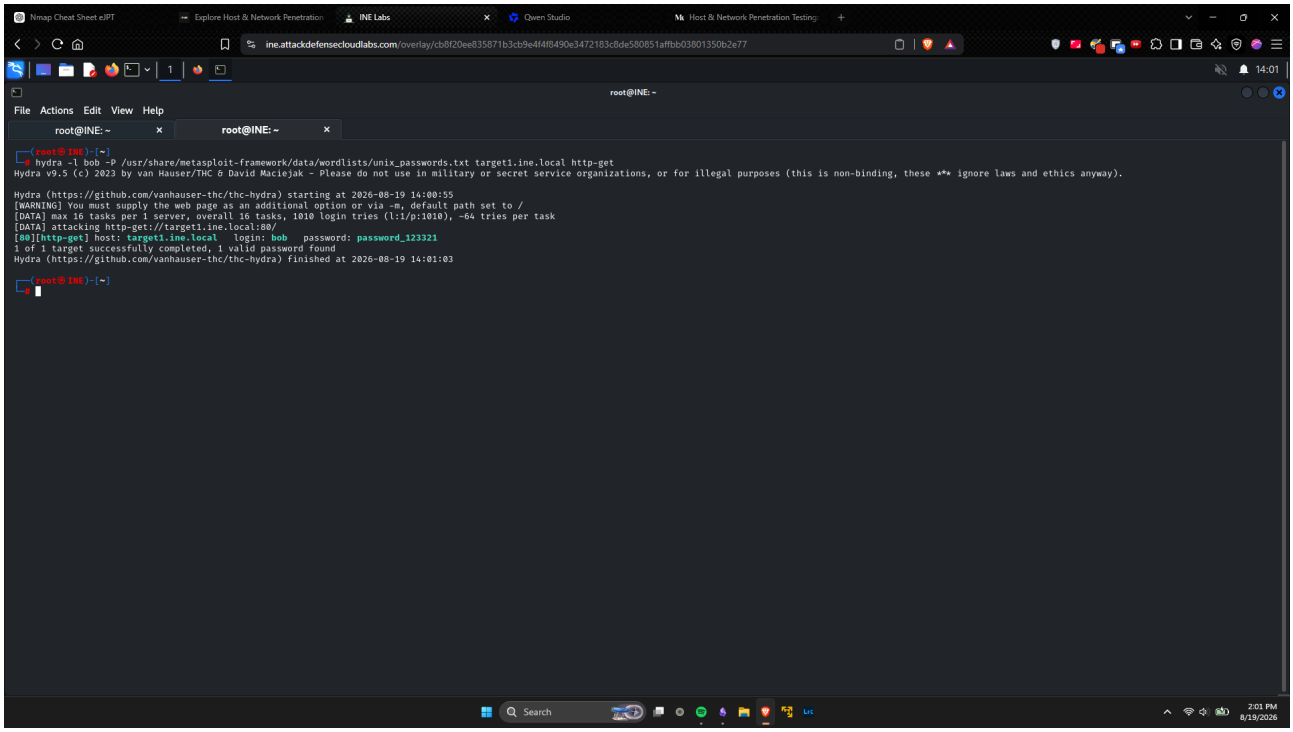


Figure 3. Hydra successfully recovers the HTTP credential for bob.

3.3 Authenticated WebDAV Enumeration — Flag 1

With the recovered credentials, the WebDAV endpoint can be accessed using Cadaver. The directory listing exposes flag1.txt alongside other files.

```
cadaver http://target1.ine.local/webdav/

dav:/> ls
flag1.txt
readme.txt
test.asp
web.config
```

The file was read directly from the authenticated WebDAV session.

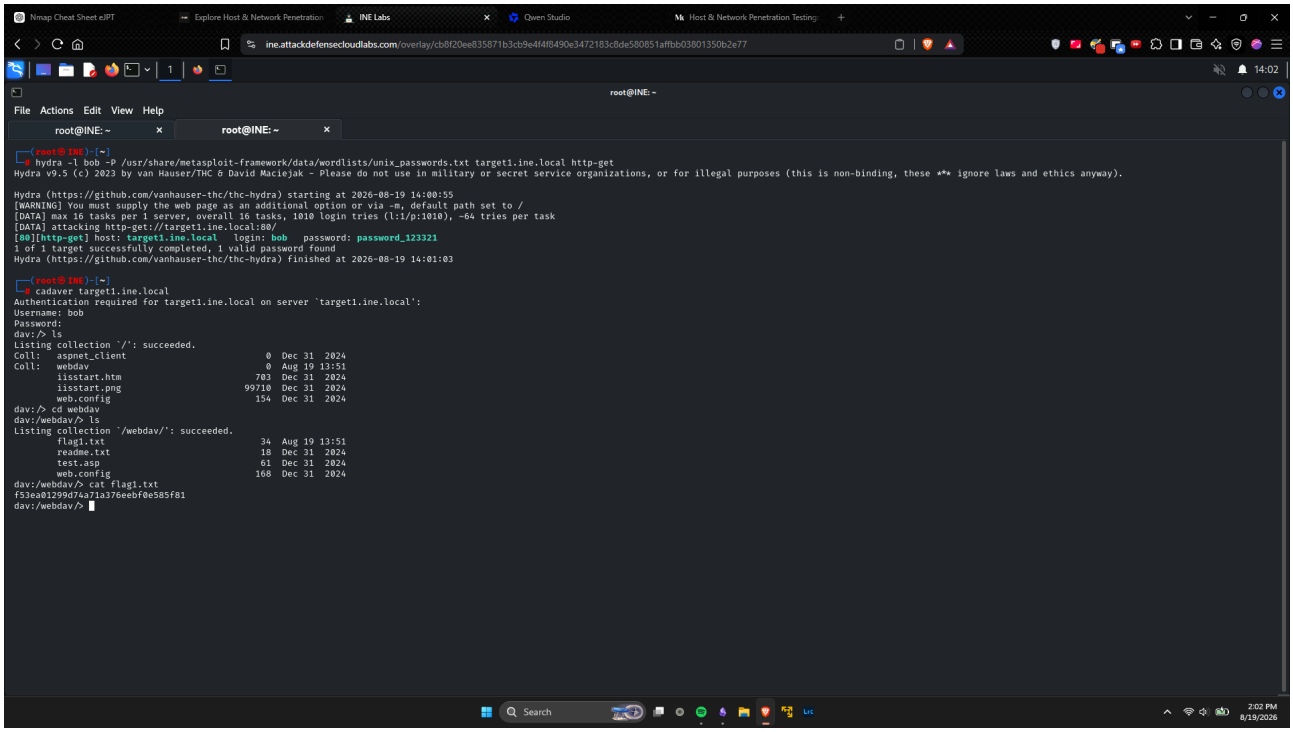


Figure 4. Authenticated Cadaver session showing flag1.txt and the recovered Flag 1 value.

```
Flag 1: f53ea01299d74a71a376eebf0e585f81
```

Security significance: authenticated WebDAV access is not inherently dangerous, but allowing ordinary application credentials to write server-executable content creates a direct route from account compromise to code execution.

3.4 WebDAV File Upload and ASP Web Shell

The lab provides an ASP web shell specifically for this exercise. Because the WebDAV directory accepts uploads, the shell can be placed in the same web-accessible location.

```
cadaver http://target1.ine.local/webdav/
dav:/> put /usr/share/webshells/asp/webshell.asp
```

The supplied evidence confirms that the upload completed successfully and that webshell.asp appeared in the WebDAV directory.

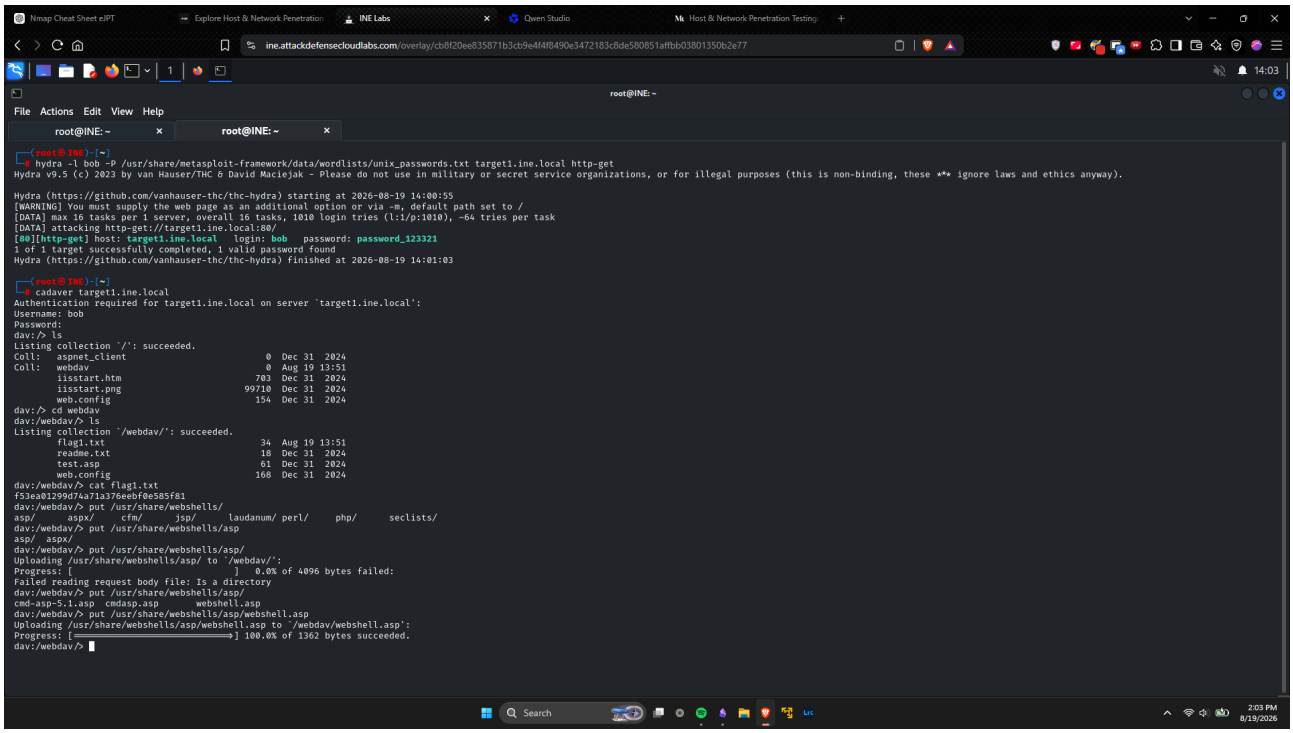


Figure 5. Cadaver upload of the supplied ASP web shell into the WebDAV directory.

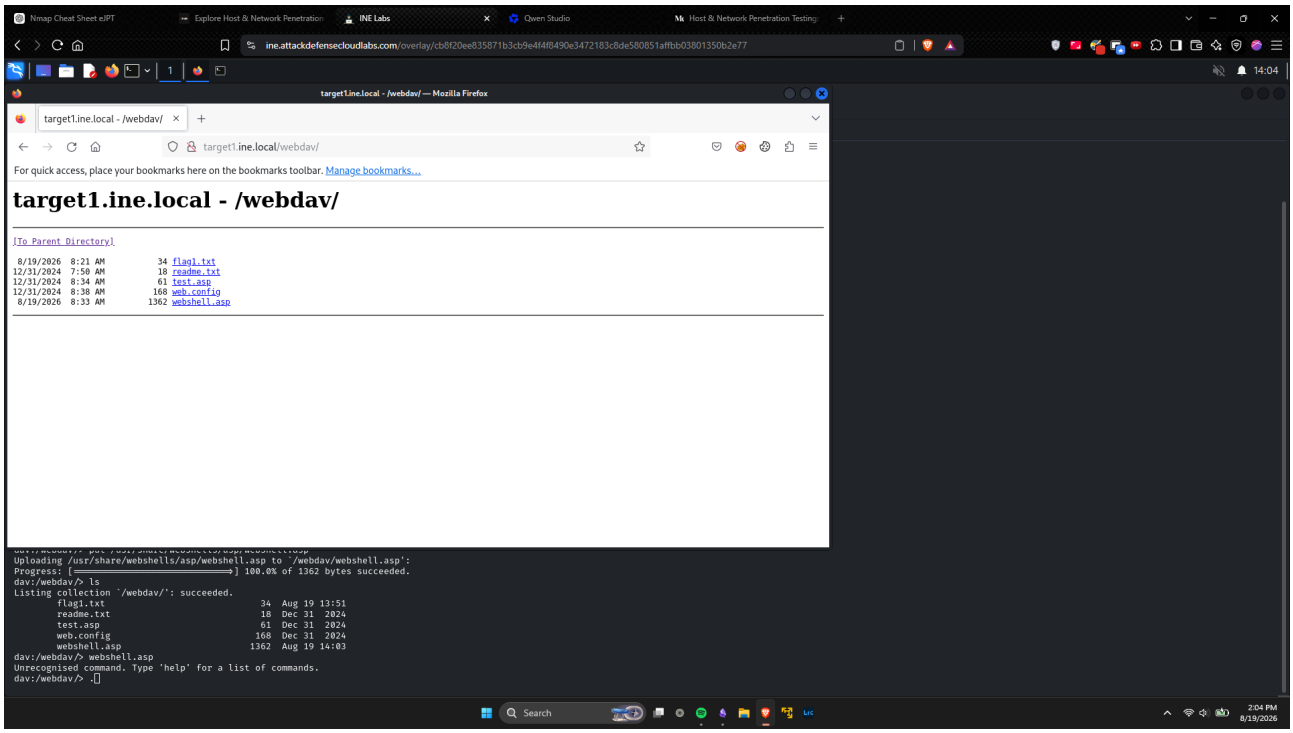


Figure 6. Browser enumeration of /webdav/ after the web shell upload; webshell.asp is now exposed.

3.5 Command Execution and Flag 2

Opening the uploaded ASP file in the browser exposes a simple command-execution interface. The task hint directs the tester to inspect the C: drive. Executing dir C:\ reveals flag2.txt in the root of the drive.

```
dir C:\
type C:\flag2.txt
```

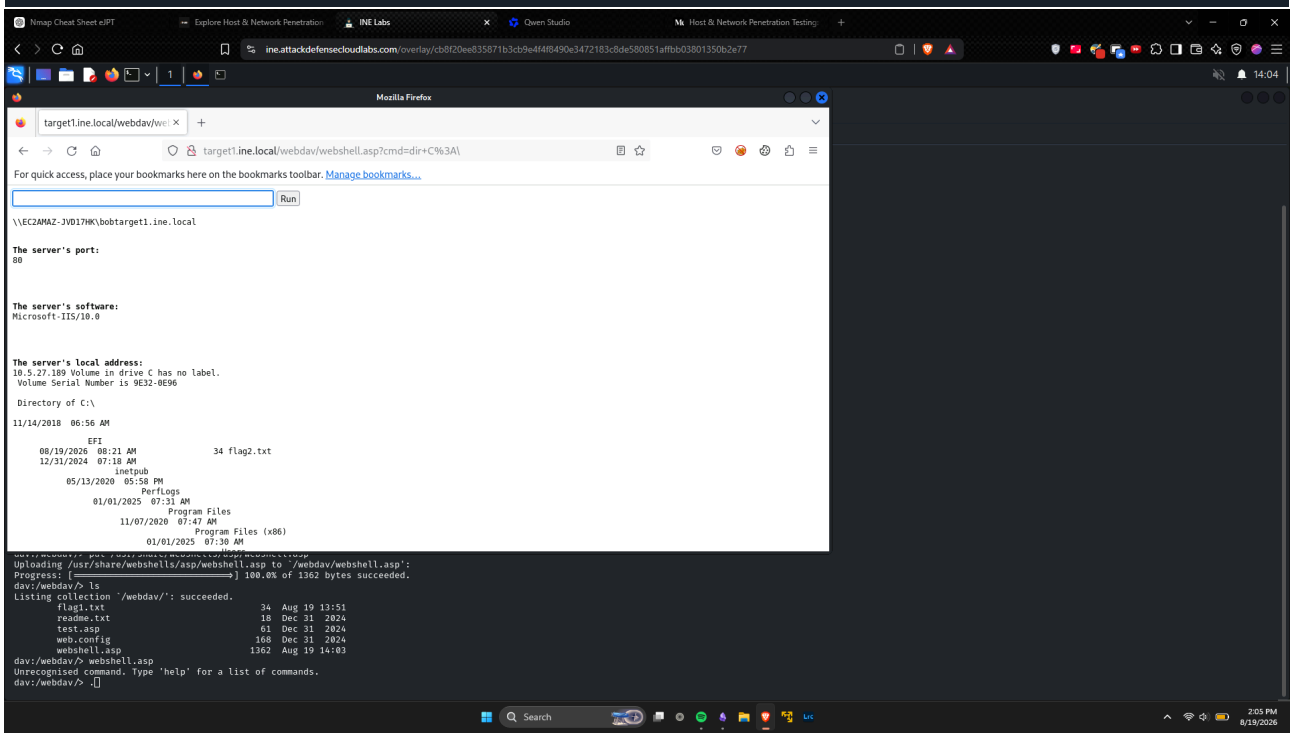


Figure 7. ASP web shell executing dir C:\ and revealing flag2.txt in the root of the Windows system drive.

The supplied follow-up screenshot shows the web shell request for type C:\flag2.txt, but the returned flag value is not visibly rendered in the screenshot. For accuracy, this report does not invent or substitute a value from another lab instance.

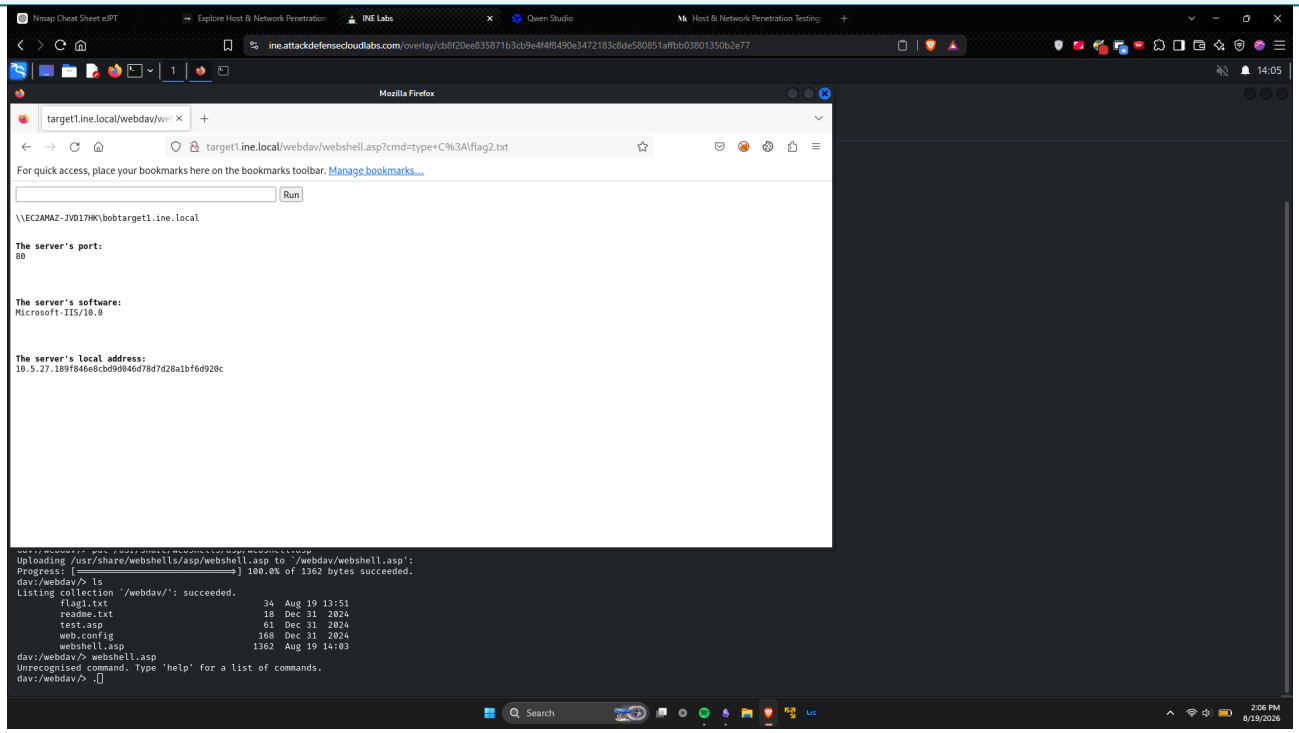


Figure 8. ASP web shell request attempting to read C:\flag2.txt. The supplied capture does not visibly display the returned hash.

```
Flag 2: captured during the lab; value not legible in the supplied evidence.
```

4. Target 2 — SMB Credential Attack Chain

Target: target2.ine.local

The second target shifts the attack surface from HTTP/WebDAV to SMB. The evidence shows SMB 2/3 support and a Windows Server 2019 host. The lab hint specifically suggests attempting to guess SMB user credentials.

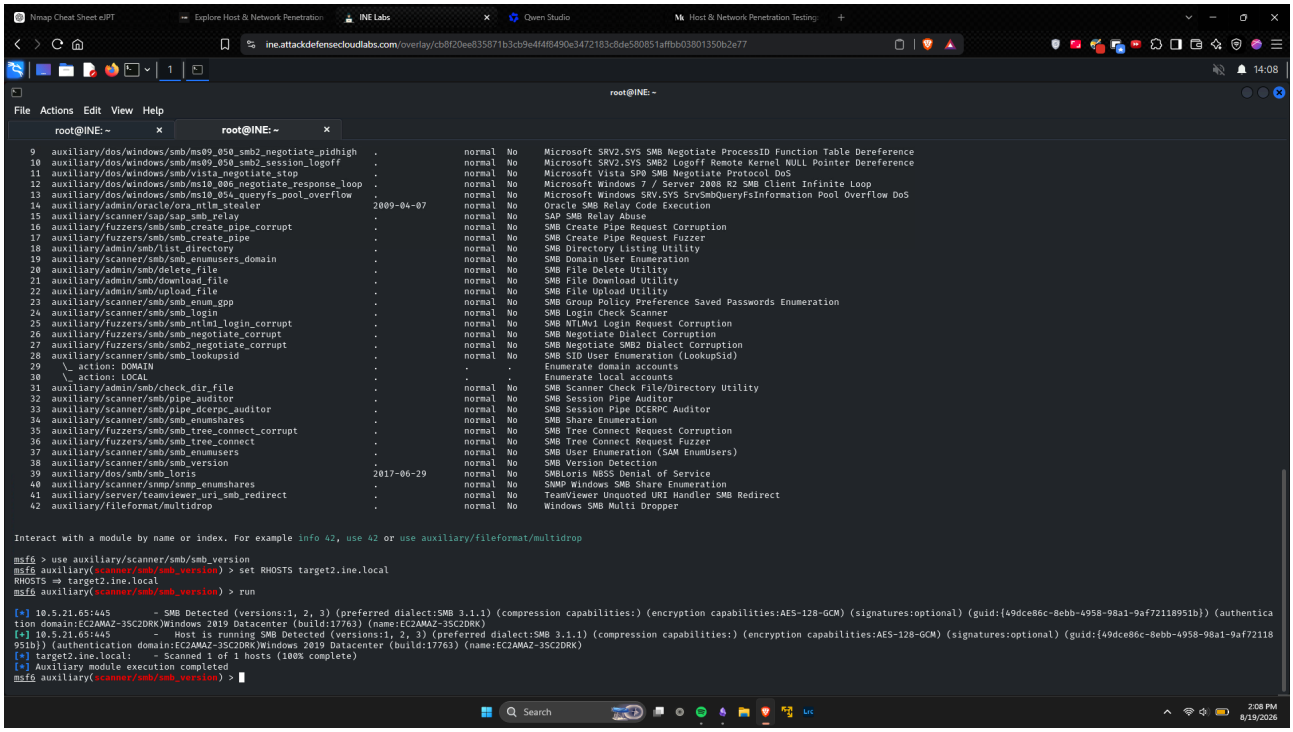


Figure 9. SMB version detection against target2, identifying SMB 2/3 and the Windows Server 2019 host.

4.1 SMB Credential Guessing

Metasploit's auxiliary/scanner/smb/smb_login module was used for credential testing. The supplied capture shows numerous failed attempts followed by a successful administrator login.

```
use auxiliary/scanner/smb/smb_login
set RHOSTS target2.ine.local
set SMBUser administrator
run
```

The successful credential was:

administrator:pineapple

The screenshot also captures an intermittent module error during the earlier brute-force run. Re-running with verbose output disabled allowed the successful credential result to be obtained. This is a useful lab lesson: tool errors do not necessarily invalidate the target; validate the module configuration and rerun the smallest necessary operation.

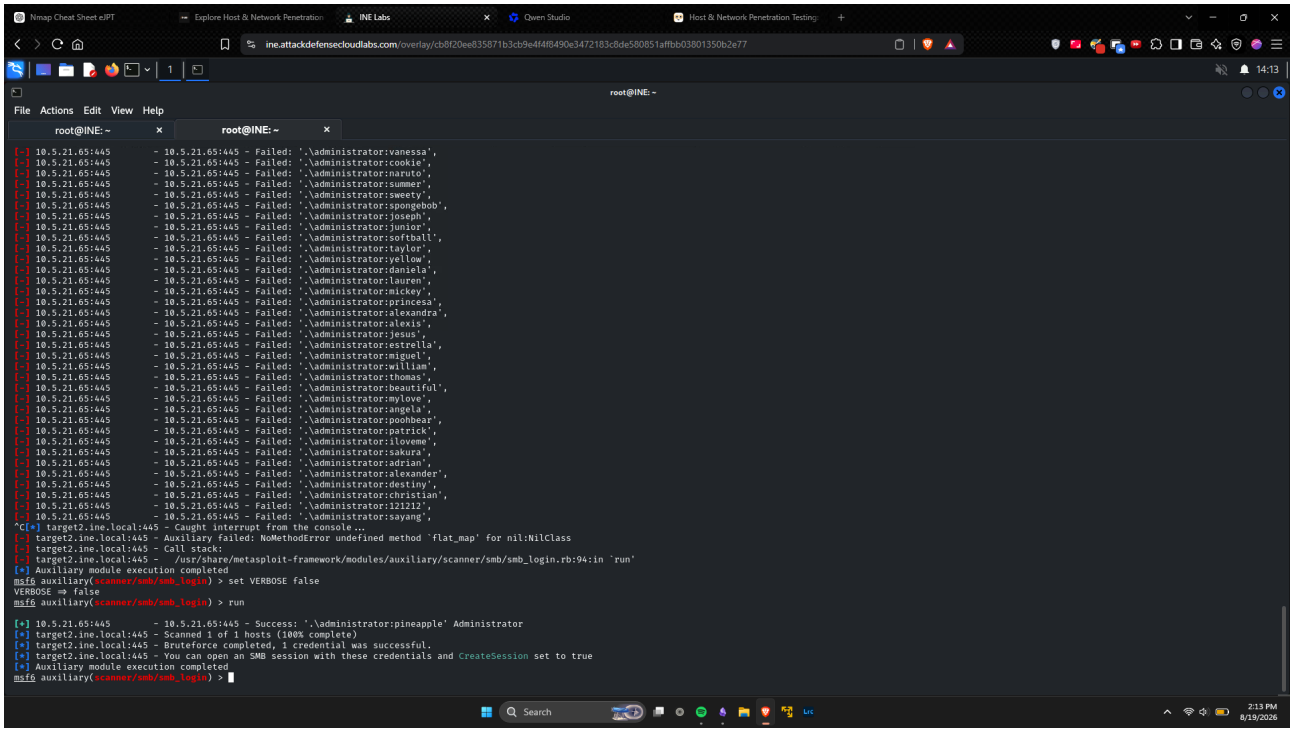


Figure 10. SMB login brute-force output showing failed attempts, a module error, and eventual success for administrator:pineapple.

4.2 Administrative Share Enumeration

With valid administrator credentials, smbclient was used to enumerate available shares. The host exposed standard administrative shares such as ADMIN$ and C$, plus additional shared resources.

```
smbclient -L //target2.ine.local -U administrator
```

Because C$ is an administrative disk share representing the Windows system drive, access to it provides substantially greater visibility than an ordinary file share.

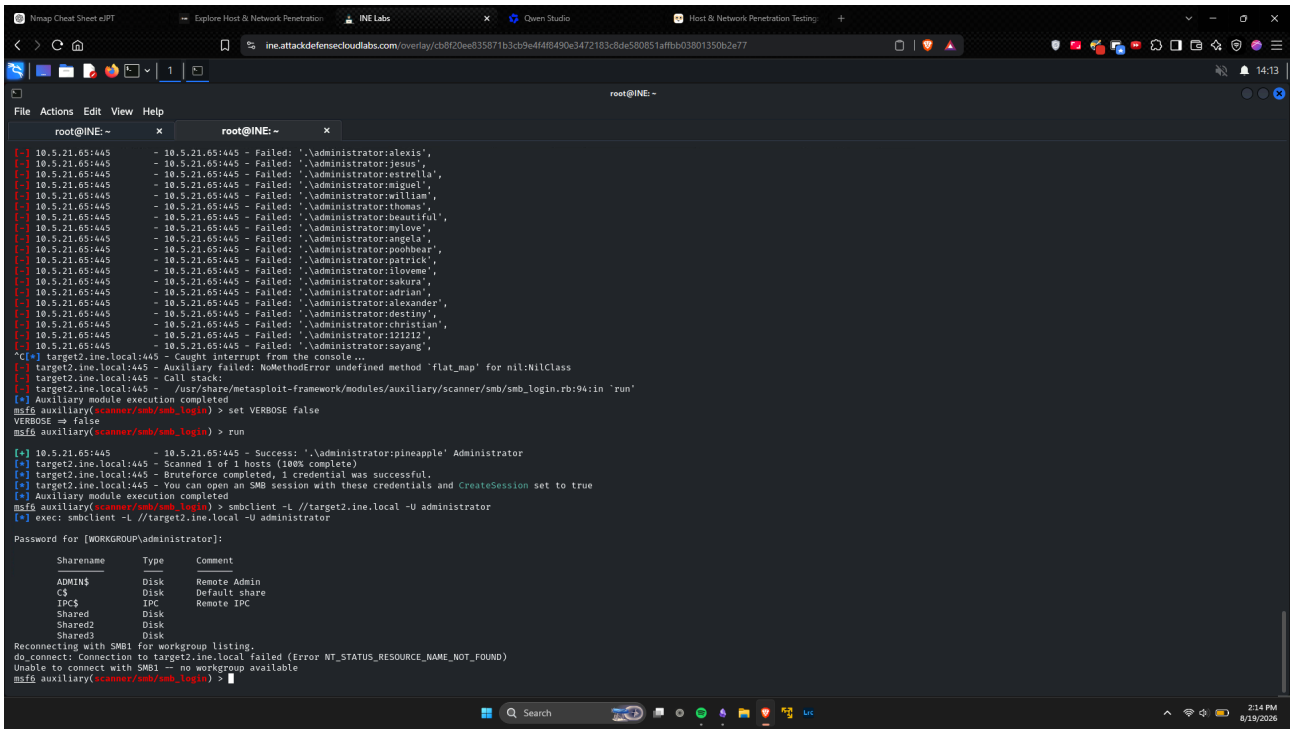


Figure 11. Authenticated SMB share enumeration showing ADMIN$, C$, IPC$ and additional shares.

4.3 C$ Administrative Share — Flag 3

The tester connected directly to the C$ administrative share and listed its contents. The root directory contained flag3.txt. Since smbclient is a remote file-transfer client rather than a full Windows command shell, the file was downloaded with get and then read locally.

```
smbclient //target2.ine.local/C$ -U administrator
smb: \> ls
smb: \> get flag3.txt
$ cat flag3.txt
```

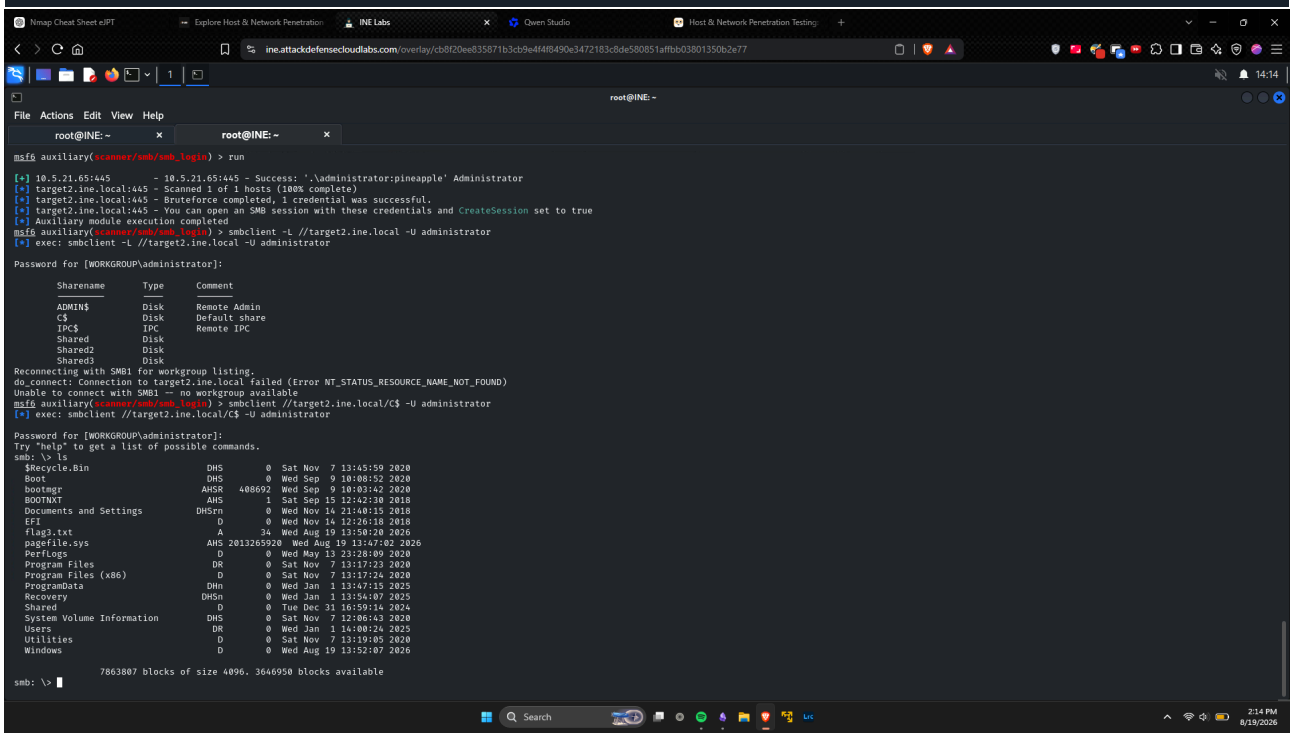


Figure 12. Authenticated C$ access and discovery of flag3.txt in the Windows system-drive root.

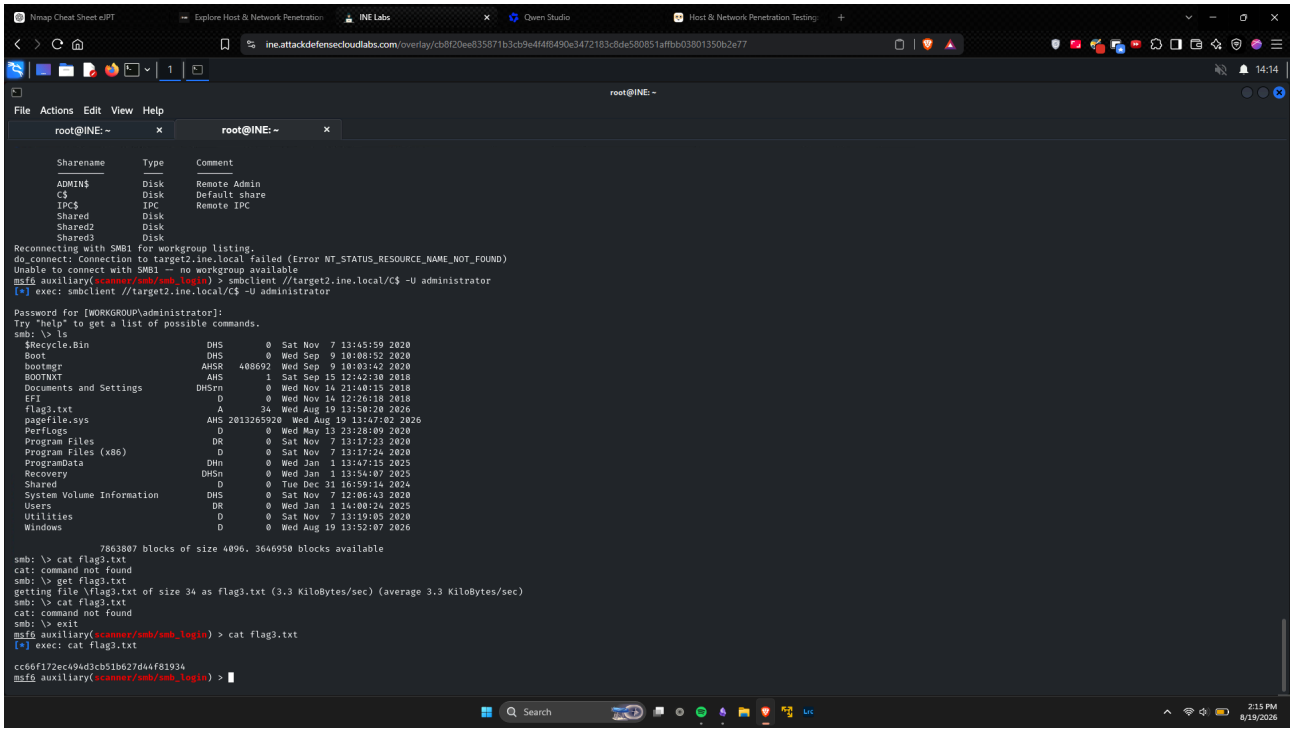


Figure 13. Downloading flag3.txt from C$ and reading it locally after exiting smbclient.

`Flag 3: cc66f172ec494d3cb51b627d44f81934`

4.4 Administrator Desktop — Flag 4

The final task hint points directly to the Administrator Desktop. From the C$ share, the session was navigated through Users\Administrator\Desktop. The directory listing revealed flag4.txt.

```
cd Users\Administrator\
cd Desktop
ls
get flag4.txt
exit
cat flag4.txt
```

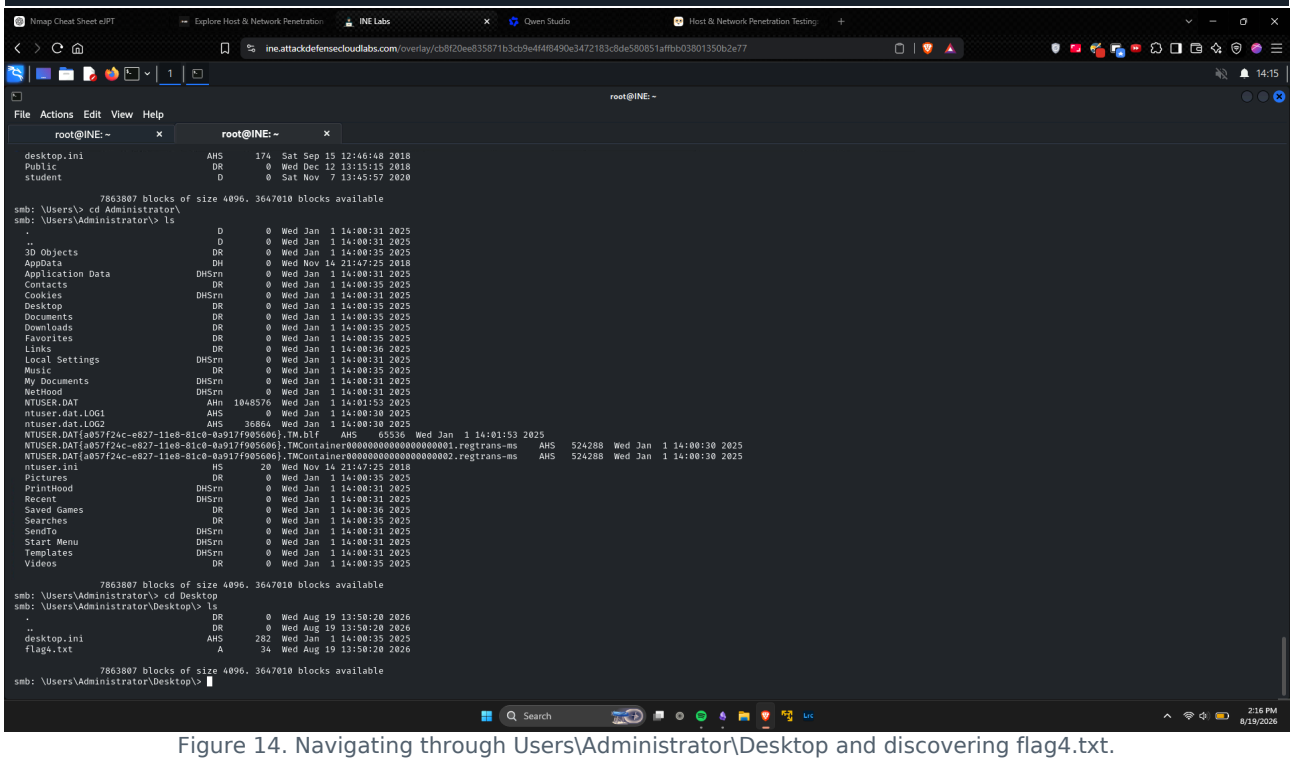


Figure 14. Navigating through Users\Administrator\Desktop and discovering flag4.txt.

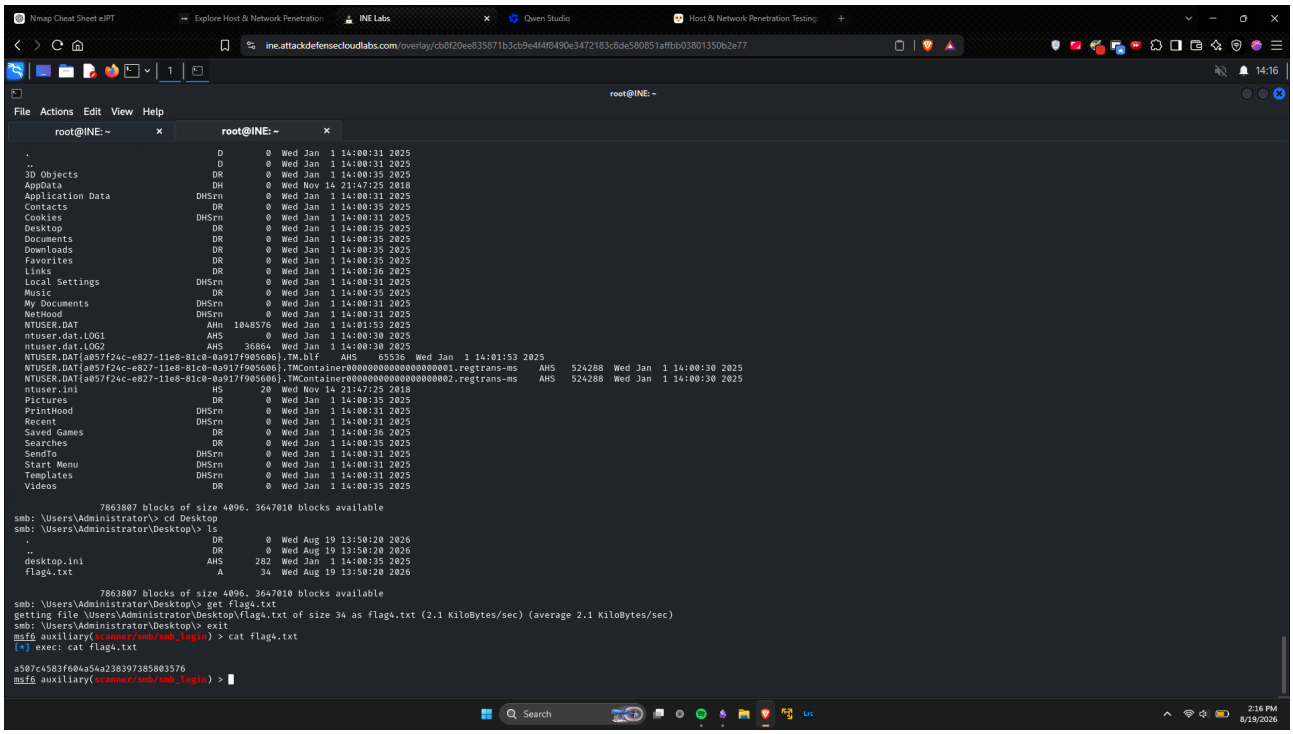


Figure 15. Retrieving flag4.txt and reading the recovered Flag 4 value locally.

```
Flag 4: a507c4583f604a54238397385803576
```

5. Findings & Security Impact

Finding	Impact	Evidence / Cause
Weak HTTP credentials	High	bob authenticated with a dictionary-guessable password.
Writable WebDAV with executable ASP	Critical	ASP support	Authenticated user could upload webshell.asp and execute commands through IIS
Weak privileged SMB credentials	Critical	administrator account accepted the weak password pineapple.
Administrative share exposure	High	Recovered administrator account accessed C$ and the Administrator profile.

Risk interpretation

The most important observation is the chaining effect. The first host does not require a memory-corruption exploit: a weak password provides authenticated WebDAV access, and a dangerous upload configuration turns that access into command execution. On the second host, a weak privileged SMB credential immediately exposes administrative shares and sensitive local files.

In a real environment, these weaknesses could support unauthorized file access, remote command execution, persistence, credential theft, or lateral movement depending on network segmentation and account privileges.

6. Remediation Recommendations

1. Enforce strong authentication

• Replace weak and reused passwords with long, unique credentials and enforce an enterprise password policy.

• Protect privileged accounts with MFA where supported and restrict interactive/remote use of administrator accounts.

2. Harden WebDAV and IIS

• Disable WebDAV where it is not required.

• If WebDAV is required, restrict write operations to dedicated non-executable storage locations.

• Prevent ASP/ASPX execution in upload directories and apply strict file-type validation.

• Run application services with the minimum filesystem privileges necessary.

3. Secure SMB

• Restrict TCP 445 exposure using segmentation and host-based firewalls.

• Disable unnecessary administrative shares where operationally appropriate.

• Use least-privilege permissions for shares and local administrators.

• Monitor repeated SMB authentication failures and unusual access to administrative shares.

4. Improve detection

• Alert on abnormal WebDAV write activity followed by execution of server-side script files.

• Monitor suspicious IIS child processes and command execution from web application worker processes.

• Detect SMB password spraying/brute-force patterns and administrative-share access from unusual hosts.

7. eJPT Takeaways

This lab reinforces several exam-relevant habits:

• Enumerate before exploiting. Identify the protocol and service before selecting a module or attack technique.

• Use the hint as an attack hypothesis. A hint about a weak password should immediately focus authentication testing; a hint about C: or Desktop should shape post-authentication enumeration.

• Understand the tool boundary. smbclient transfers files; it is not a Windows shell. Download a file and inspect it locally when necessary.

• Keep evidence. Successful commands, errors, recovered credentials, and file listings are all useful in a professional report.

• Prefer the simplest valid path. The lab can be solved with a small set of focused tools rather than a large exploit chain.

Condensed attack graph

```
target1.ine.local
HTTP 80
↓
Hydra → bob:password_123321
↓
WebDAV
↓
upload webshell.asp
↓
IIS command execution
↓
C:\flag2.txt

target2.ine.local
SMB 445
↓
smb_login → administrator:pineapple
↓
C$
├── flag3.txt
└── Users\Administrator\Desktop\flag4.txt
```

Evidence note

Flag values in this report are transcribed only where they are visibly present in the supplied screenshots. Flag 2 is intentionally marked as not legible rather than importing a value from another instance of the lab, because INE lab instances may use different flag material.

Reference

Primary reference: InfoSec Write-ups — “Host & Network Penetration Testing: System-Host Based Attacks CTF 1”. The linked article was used as the structural/methodological reference; the commands, observations, screenshots and evidence presented here are based on the supplied lab captures.

End of Report